



Access to AWS

There are 3 ways to access an AWS account:

- [via Cloudshepherd](#)
- [as IAM user](#)
- [via programmatic access](#)
- [via openID connect IdP](#)

Via Cloudshepherd

How to access an AWS account via Cloudshepherd is described in the [Cloudshepherd User Guide](#), including how to grant or revoke access to colleagues.

Standard roles available in project accounts

Following roles are pre-created in every project account and can be used. Access for users is managed in responsibility of the user admin of the project in Cloudshepherd.

- **CS_DTIT_Project_Admin** , administrative access to resp. environment
- **CS_DTIT_Project_Member** , view-only access (can see configurations, but not the data)
- **CS_DTIT_Project_Key_Admin** , permission to manage the keys in the account

If a custom role is required by the project, e.g. to implement the least privilege principle, those can be created via Cloudshepherd as well.

The permissions of the new role need to be set on AWS side by the user admin (by attaching the respective IAM policies to the role).

External users

External users normally do not have access to any kind of production environment. Also they will normally not use Cloudshepherd for access to DTIT AWS accounts, but rather use an [IAM user](#).

For the case that production AWS access is needed they would need to use [Oracle Secure Global Desktop](#), see [cookbook](#).

IAM access / external users

IAM user based access can only be granted in a highly regulated way for externals who need access to the DTIT environment/project account.

Restrictions/policies for external access

We can provide for external users centrally managed IAM users in dtit-iam account under certain restrictions described below which consider the security requirements.

1. Users who are in Telekom AD must not get an IAM user but are supposed to use their AD user for sign-in into AWS.
2. IAM console users need to be centrally managed, that's why they are created only in DTIT-IAM account. Creation of IAM console users (human users that can login to AWS console via Webbrowser) in project accounts is blocked via SCP (this is not affecting programmatic access).
3. As user name we use the business email address of the user.
4. We enforce MFA for these users.
5. External users can be created via two channels:
 - Submitting a request through the CCoE-Servicedesk.
 - Cloud owners or deputies with appropriate permissions can create external users through CloudShepherd, which can be accessed via the [Permissions External Users](#) menu. Please note that this service is only available for cloud owners or deputies.
6. Initial password is send to the user via some encryption gateway like <https://www.telesec.de/de/eegw> or Vault.
7. The following password policies are applied for the console access password:
 - Minimum password length is 12 characters.
 - Require at least one uppercase letter.
 - Require at least one lowercase letter.
 - Require at least one number.
 - Require at least one non-alphanumeric character.
 - The users are allowed to change their own password.
 - Passwords expire after 90 days.
 - Passwords reuse of the last 5 passwords is prevented.

8. Each user has time limited permissions, i.e. the user permissions automatically expire. Latest possible and default expiration date is three months after request.
9. Only non-prod accounts can be accessed with higher permissions than ViewOnly by the centrally managed IAM users.
10. Users need to manage their expiration date themselves, i.e. no monitoring or notifications are in place (at this time).
11. Requesting new external users or extending lifetime for existing ones needs to be done by account owner via CCoE Servicedesk including the parameters account-id, username (=e-mail address), IAM role in project account and time period, which can be at most three months.
12. Users that are expired for more than four weeks will be deleted.
13. Account owner is responsible to inform CCOE immediately via ServiceDesk about changes regarding external users (e.g. leaves), so that the user can be removed or changed accordingly (parameters as above and what shall be changed).

Sign-in instructions for access via dtit-iam

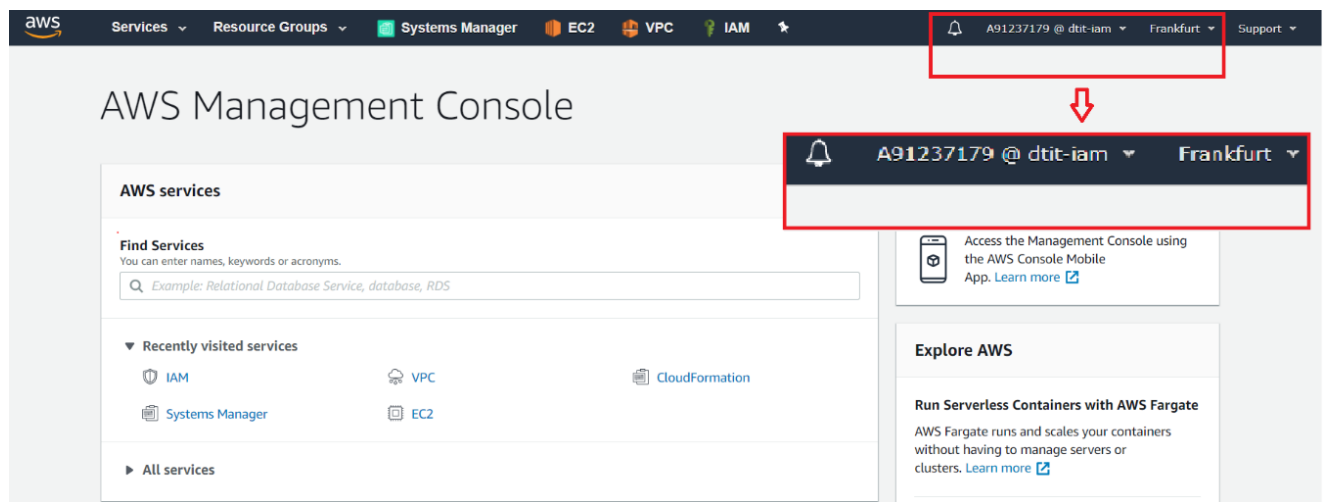
Please walk through following instructions step by step after you received your credentials in order to sign in.

Management Console

1. You receive an e-mail with sign-in url <https://dtit-iam.signin.aws.amazon.com/console>
2. Your username is your business e-mail address
3. You receive a password via a secure communication channel
4. You login and need to change your password. Account ID/alias would always be "**315005456645**" or "**dtit-iam**" at this point.

Important : Note that we have set a password policy, so your password needs to be strong as described above. If you experience the (not very helpful) error message "User is not authorized to perform iam:ChangePassword." just try again with a strong password.

5. Now you are logged into the central authentication account for external users of DTIT environment



Note that you have virtually no privileges at this point in time. You are just allowed to change your password and configure multi-factor authentication (MFA) for your user. You can only switch to your target account after you configured MFA!

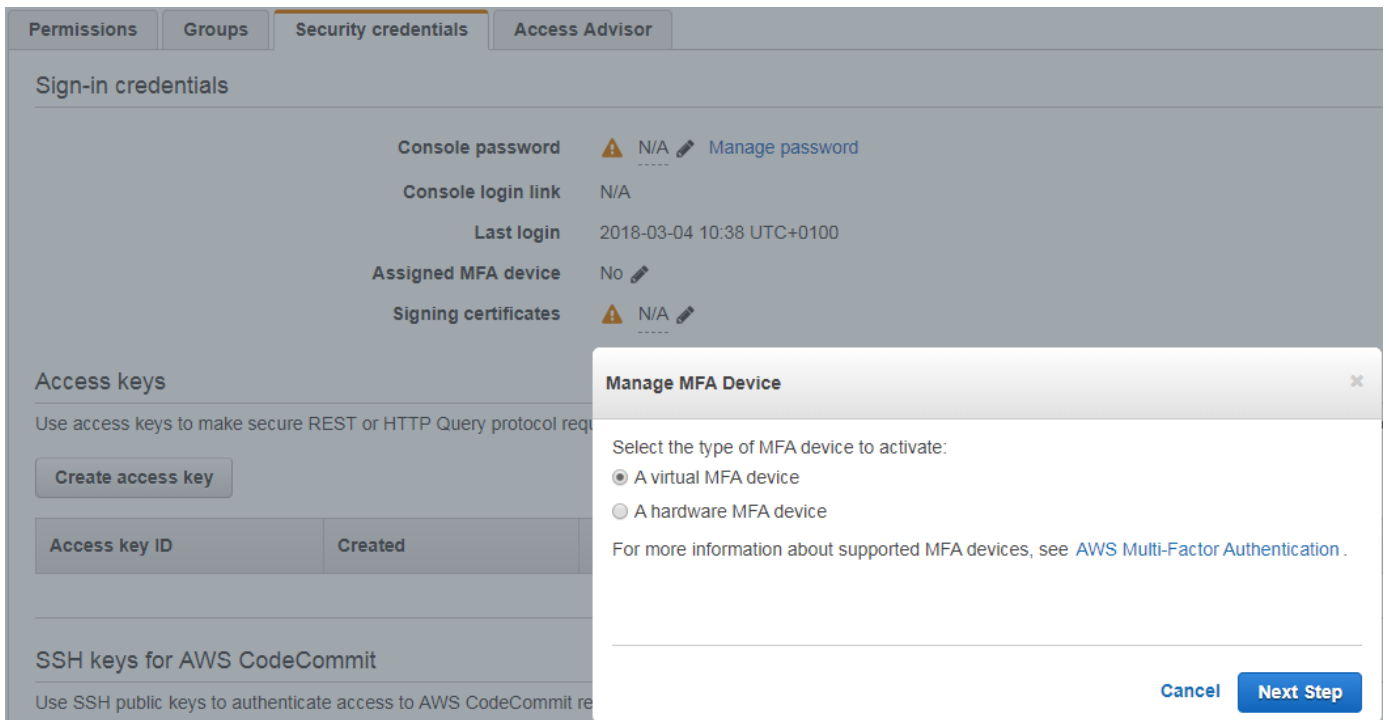
Configure multi-factor authentication

Using MFA is an AWS best practice for ensuring high security standards and a DTIT security policy.

1. If you have a business phone, install the app google authenticator on your mobile. It is available for the iPhone, see <https://itunes.apple.com/de/app/google-authenticator/id388497605>

If you do not have a business phone, you can use a desktop application like Authy (<https://authy.com/download/>).

1. Open your user in the IAM service, tab "Security credentials". Edit "Assigned MFA device". Or directly use the following link: [https://console.aws.amazon.com/iam/home?#/users/<your_username>\\$manageMFA?section=security_credentials](https://console.aws.amazon.com/iam/home?#/users/<your_username>$manageMFA?section=security_credentials)

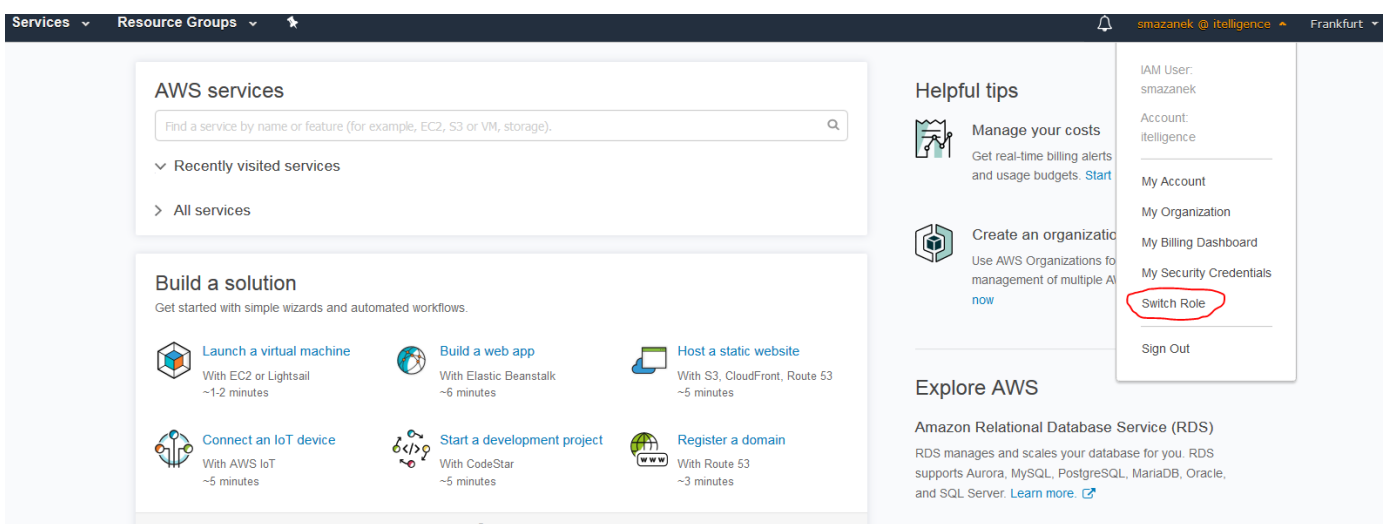


1. Select "A virtual MFA device"
2. Scan the QR code presented to you by AWS with google authenticator app or enter the secret key manually. Then you need to enter two successive codes (a new code is generated every 30 seconds).
3. If you get the message that your MFA device has been configured successfully, **logout and login again**. After entering your password you will see that you need to provide the code shown in Google Authenticator.

Switch into your target account

With MFA configured you now have the privilege to go to other AWS accounts according to your privileges. The accounts you are privileged for at the time of the creation of your user are given in your welcome e-mail.

1. Click on your user in the top-right corner of the AWS console and select "Switch Role"



1. Enter the required information to switch to your target account

Switch Role

Allows management of resources across AWS accounts using a single user ID and password. You can switch roles after an AWS given you the account and role details. [Learn more.](#)

Account* ⓘ

Role* ⓘ

Display Name ⓘ

Color a a a a a a

*Required

[Cancel](#)

[Switch Role](#)

- enter the account ID (received by an email) of the target account
- enter the role you want to work with, mostly this will be " **DTIT_Project_Admin**" or " **DTIT_Project_Member**"

You can also choose a display name, but the default value is quite reasonable so you can leave it as it is. Instead of filling in the form you can also switch to the account directly using a URL with the following structure:

[https://signin.aws.amazon.com/switchrole?account= |<accountname|> &roleName=__|<rolename|>](https://signin.aws.amazon.com/switchrole?account=|<accountname|> &roleName=__|<rolename|>)

Now you have successfully activated your IAM user, changed your password, configured your MFA device and switched to your target account!

If you run into any issues during this process, please contact CCoE Servicedesk.

Setting an account alias

If you would like to set a readable name for your account you can do so as described here:

https://docs.aws.amazon.com/de_de/IAM/latest/UserGuide/console_account-alias.html#AboutAccountAlias

Compliance regarding user management

Console users/login profiles cannot be created in project accounts (blocked by SCP).

Note also that it is not allowed to assign permissions that exceed the permissions of the user's role. Example: A Lambda function needs an IAM role assigned to it. You must not assign a role to a Lambda function that has more permissions than your own user. Note that this is not actively blocked by the landing zone as that would require the configuration of so-called AWS permission boundaries which are not very user-friendly. In doubt please consult with your project's user admin or CCoE Servicedesk.

Programmatic Access

Programmatic access describes access beyond the AWS management console. This includes API calls, use of the AWS CLI, use of Tools for Windows PowerShell, or other development tools. To that end, an [access key can be generated together with a secret access key](#) (similar to username and password).

Here the available/approved options for programmatic access to your AWS account:

- Whitelist source IP addresses for your programmatic user
- Pro: only API calls originating from office network can be allowed that way, only option for creating programmatic users in project accounts, **recommended by our corporate security for e.g. CI/CD pipelines of internal applications running at on-prem gitlab.**
 - Implementation:
 - You can create a programmatic user as self-service via [AWS Service Catalog](#)
 - you need to know the IP address, i.e. proxy ranges (DTAG Magdeburg/Biere "80.146.191.128/27" and "80.146.191.192/27" or when using special internet access SIA "62.156.151.0/28", for Magenta CI/CD the IP-Range is "80.158.0.0/16") You can find more informations about the public proxy-ip-adresses on [YAM](#) or in this [Magenta CI/CD Article](#)

To use the external workbenches, please consider the whitelisting:

```
- workbenches with *.psst.t-online.corp and *.workbench.telekom.de use the public IP-Address 217.170.177.99
- workbenches with *.devops.telekom.de use the public IP-Address 80.158.21.12
```

Further information can be found [here.](https://cid-wbench.psst.t-online.corp/documentation/production/public/proxy.html)

After deploying via Service Catalog you need to attach the respective permissions to the user and create an access key in IAM.

This solution has limitations, these limitations only apply to service-to-service access or endpoint based connection from within AWS because of the IP whitelisting.

The following services currently do not support [aws:ViaAWSService](#):

- Amazon EC2
 - AWS Glue
 - AWS Lake Formation
 - AWS OpsWorks
- Use of roles within AWS (best practice), examples: download temporary credentials for AWS CLI via Cloudshepherd, use EC2 instance profile/role etc.
 - Pro: easy to secure as no permanent credentials required
 - Restrictions: only works within the same AWS account, cannot be used from on-prem
 - Use of [MFA \(multi-factor authentication\) on your programmatic user](#)
 - only allowed/enforced by Security for external users centrally managed in DTIT-IAM (see above)

Of course, these are just the basic different concepts for authentication of programmatic access. Several other measures need to be taken into account as well, most importantly rotating the credentials on a regular basis and not putting any credentials into source code.

Via openID Connect identity provider (GitLab only)

OpenID Connect is a simple identity layer on top of the OAuth 2.0 protocol. It can be used with the AWS IAM identity providers.

An openID Connect identity provider is deployed by default in every landing zone account created after 01.10.2022. It is also possible to toggle this through Cloudshepherd from the services section. It creates a trust relationship between GitLab and the AWS account. It can be used to access an AWS environment from a GitLab runner without any programatic users. It allows for secure and easy pipeline deployments. You can find more information on how to use and deploy the openID connect IdP in [this cookbook](#). More technicals documentation can be found [here](#)

Principle of least privilege

It is a security best practice and a must when using public cloud to follow the principle of least privilege when creating IAM policies to grant entities access to AWS. You can do this by only setting permissions that are needed to perform the task. In addition, defining specific resources to which the permissions apply under specific conditions is necessary.

AWS provides a tool to help with this. The AWS IAM Access Analyzer analyzes your AWS CloudTrail logs to identify actions and services that have been used by an IAM entity (user or role) within a specified date range. It then generates an IAM policy that is based on that access activity. You can use the generated policy to refine an entity's permissions by attaching it to an IAM user or role. Find out more about it [here](#).

 [Edit this page](#)